

SOX IT General Controls (ITGC) Assessment Questionnaire

This questionnaire is used to assess the design and operating effectiveness of IT General Controls over financially significant systems, as required under Sarbanes-Oxley Act Section 404. Responses should reference supporting evidence (policies, logs, SOC reports) where applicable.

A. IT Governance & Organization

1. Does the organization have a formal IT governance framework (e.g., COBIT, ITIL) in place?

Response: _____

2. Is there a documented IT organizational structure with clearly defined roles and responsibilities?

Response: _____

3. Does the CIO or IT leadership report to the audit committee or board on the state of IT controls?

Response: _____

4. Are IT policies and procedures formally documented, approved, and reviewed at least annually?

Response: _____

5. Is there a process to ensure IT control deficiencies are identified, tracked, and remediated?

Response: _____

B. Logical Access Controls

6. Are user access provisioning and de-provisioning processes formally documented and followed?

Response: _____

7. Is multi-factor authentication (MFA) required for access to financially significant systems?

Response: _____

8. Are user access rights reviewed and recertified on at least a semi-annual basis?

Response: _____

9. Is access to production systems and data restricted based on the principle of least privilege?

Response: _____

10. Are privileged (administrator) accounts subject to enhanced monitoring and periodic review?

Response: _____

11. Is there a documented process to immediately revoke access upon employee termination?

Response: _____

12. Are generic, shared, or service accounts inventoried and subject to compensating controls?

Response: _____

13. Is segregation of duties (SoD) enforced for financially sensitive processes and system functions?

Response: _____

C. Change Management Controls

14. Is there a formal change management process that governs changes to financially significant systems?

Response: _____

15. Are all system changes tested in a non-production environment before deployment to production?

Response: _____

16. Is authorization from business owners required before changes are promoted to production?

Response: _____

17. Are emergency or expedited changes subject to retroactive approval and documentation?

Response: _____

18. Is there a process to ensure unauthorized changes to production are detected and investigated?

Response: _____

19. Are application developers restricted from direct access to the production environment?

Response: _____

D. IT Operations & Job Scheduling

20. Are batch jobs and scheduled processes that support financial reporting formally documented?

Response: _____

21. Are failed or abnormal job completions detected, logged, and investigated promptly?

Response: _____

22. Is there a process to ensure that data interfaces and file transfers between systems are complete and accurate?

Response: _____

23. Are system and application logs retained for a sufficient period to support audit and investigation?

Response: _____

24. Are capacity and performance thresholds monitored to ensure system availability?

Response: _____

E. Backup & Recovery Controls

25. Are backups of financially significant systems and data performed and tested on a regular schedule?

Response: _____

26. Is the recovery time objective (RTO) and recovery point objective (RPO) formally defined and tested?

Response: _____

27. Are backup media stored offsite or replicated to a geographically separate location?

Response: _____

28. Has disaster recovery been tested within the past 12 months with documented results?

Response: _____

29. Is there a documented and board-approved Business Continuity Plan (BCP)?

Response: _____

F. Security & Vulnerability Management

30. Is vulnerability scanning performed regularly on systems that support financial reporting?

Response: _____

31. Are critical and high-severity vulnerabilities remediated within documented SLA timeframes?

Response: _____

32. Is penetration testing of financially significant systems conducted at least annually?

Response: _____

33. Are security patches for operating systems and applications applied on a documented schedule?

Response: _____

34. Are network boundaries of financially significant systems protected by firewalls with reviewed rule sets?

Response: _____

35. Is security incident response documented, tested, and reported to management and audit committee?

Response: _____

G. End-User Computing (EUC) Controls

36. Has the organization identified and inventoried spreadsheets and EUC tools used in financial reporting?

Response: _____

37. Are EUC tools subject to version control and access restrictions?

Response: _____

38. Is there a process to validate inputs, calculations, and outputs of financial EUC applications?

Response: _____

39. Are changes to financially significant EUC tools subject to the change management process?

Response: _____

H. Vendor & Third-Party IT Controls

40. Are SOC 1 Type II reports obtained and reviewed annually for all financially significant service providers?

Response: _____

41. Are the user control considerations identified in SOC reports evaluated and addressed?

Response: _____

42. Is there a process to monitor and manage IT risks introduced by third-party vendors?

Response: _____

43. Are service level agreements with IT vendors documented and subject to periodic review?

Response: _____